FURTHER NMAP

Advanced Network Scanning & Enumeration

TryHackMe Room — Cyber Security Group Presentation

What we'll cover:

- Ports & Scanning Basics
- TCP Scan Types
- UDP & Special Scans
- NSE Scripts
- Output & Verbosity
- Firewall Evasion

WHAT IS NMAP?

Nmap (Network Mapper) is the industry-standard tool for port scanning and network reconnaissance.

It scans targets for open ports, running services, OS versions, and vulnerabilities — the first step in almost every pentest.

Understanding Ports

Every computer has 65,535 ports — virtual doors that let services communicate.

- 0–1023 = Well-known ports (1,024 standard)
- 80 = HTTP • 443 = HTTPS
- 22 = SSH • 445 = SMB • 3306 = MySQL

Port States

Open	Service actively listening — a potential entry point
Closed	No service listening — port is reachable but inactive
Filtered	Firewall blocking — Nmap can't tell if open or closed

Basic Syntax:

```
nmap [scan type] [options] <target IP>

nmap -sS -sV -O -p 1-1000 192.168.1.1
```

🔌 TCP SCAN TYPES

-sT

TCP Connect Scan

Completes the full TCP 3-way handshake (SYN → SYN/ACK → ACK).

✔ Works without root/sudo privileges

✗ Loud — leaves logs on target. Slower than SYN scan.

Requires sudo: No

-sS

SYN / Stealth Scan

Sends SYN, waits for SYN/ACK, then sends RST instead of ACK — never completes the handshake.

✔ Faster, stealthier — often not logged. Default scan.

✗ Requires root/sudo privileges to run.

Requires sudo: YES

-sU

UDP Scan

Sends UDP packets. No response = open|filtered. ICMP 'unreachable' = closed.

✔ Finds UDP services: DNS (53), SNMP (161), DHCP (67)

✗ Very slow. Often run on top ports only: --top-ports 20

Requires sudo: YES

💡 TCP 3-Way Handshake: SYN → SYN/ACK → ACK | SYN scan breaks it: SYN → SYN/ACK → RST (half-open = stealthy)

⚡ SPECIAL SCAN TYPES

These scans are used to evade basic IDS/firewalls by sending unusual flag combinations. Especially useful on Linux/Unix targets.

-sN NULL Scan

Sends a TCP packet with NO flags set. If port is open: no response. If closed: RST returned.

Works on: Linux/Unix | Windows returns RST for all — not reliable

-sF FIN Scan

Sends a TCP FIN flag (normally used to close a connection). Open ports ignore it; closed ports reply with RST.

Works on: Linux/Unix | Windows returns RST for all — not reliable

-sX Xmas Scan

Sets FIN, PSH, and URG flags — 'lights up like a Christmas tree'. Same response rules as NULL/FIN.

Named after the blinking lights effect of all flags being set simultaneously

-sn Ping Sweep

No port scan — just checks which hosts are alive on a network. Sends ICMP echo + TCP probes.

Example: nmap -sn 172.16.0.0/16 to sweep the full 172.16.x.x network

⚠️ NULL, FIN & Xmas scans all show open|filtered if no response — Microsoft Windows responds with RST for ALL ports, making them unreliable on Windows.

⚙ KEY NMAP SWITCHES

Detection

```
-sV  Detect service versions
-O   Detect operating system
-A   Aggressive (OS + version + scripts +
traceroute)
```

Output

```
-v   Increase verbosity
-vv  Verbosity level 2 (recommended)
-oA  Save in all 3 formats
-oN  Save in normal format
-oG  Save in grepable format
```

Port Selection

```
-p 80         Scan port 80 only
-p 1-1000     Scan ports 1 to 1000
-p-           Scan all 65,535 ports
--top-ports 20  Most common 20 ports
```

Timing

```
-T0  Paranoid (IDS evasion, very slow)
-T1  Sneaky
-T3  Normal (default)
-T4  Aggressive (CTF recommended)
-T5  Insane (very noisy)
```

💡 Always save results: nmap -sS -sV -O -oA scan_results <target> — saves .nmap .xml .gnmap files for reporting

📜 NSE — NMAP SCRIPTING ENGINE

What is NSE?

The Nmap Scripting Engine transforms Nmap from a simple scanner into a full recon and exploitation framework. Scripts are written in the Lua programming language and stored in /usr/share/nmap/scripts/.

Script Categories

`safe`	Safe to run on any target — no impact on the system
`intrusive`	Risky — may crash services or trigger alerts
`vuln`	Check for known vulnerabilities
`exploit`	Attempt to exploit vulnerabilities found

Using NSE Scripts:

```
# Run a specific script:
nmap --script=http-title <target>

# Run multiple scripts:
nmap --script=smb-enum-shares,smb-enum-users <target>

# Run all scripts in a category:
nmap --script=vuln <target>

# Pass arguments to a script:
nmap --script=http-put --script-args http-put.url='/path',http-put.file='file.txt' <target>
```

🔍 Find scripts: `ls /usr/share/nmap/scripts/ | grep smb` OR `grep -r 'categories' /usr/share/nmap/scripts/*.nse | grep vuln`

FIREWALL EVASION TECHNIQUES

Firewalls block certain scans. Nmap has built-in techniques to work around them:

-Pn Skip Host Discovery	By default Nmap pings hosts first. Windows firewalls block ICMP (ping), so Nmap thinks the host is dead and skips it. -Pn tells Nmap to skip the ping and treat all hosts as alive — essential for Windows targets.	`nmap -Pn -sS <target>`
-f Fragment Packets	Splits packets into smaller fragments, making it harder for firewalls and IDS to detect the scan pattern. Each fragment is too small to trigger signature-based detection rules.	`nmap -f <target>`
--mtu Set MTU Size	Manually set the Maximum Transmission Unit (packet size). Must be a multiple of 8. Gives more control over packet fragmentation than -f alone.	`nmap --mtu 16 <target>`
--scan-delay Add Timing Delay	Add a delay between probe packets to slow the scan below IDS rate-detection thresholds. Useful on unstable networks too.	`nmap --scan-delay 1000ms <target>`
--data-length Append Random Data	Appends an arbitrary length of random data to packet payloads, making each packet a different size — harder to fingerprint and filter.	`nmap --data-length 200 <target>`

⚠ *Always use these ethically and only on networks / systems you have permission to test.*

PRACTICAL SCANNING WORKFLOW

A typical pentest recon workflow using Nmap — from first contact to full enumeration:

03

Full Port Scan

```
nmap -sS -p- -T4 <target>
```

Scan all 65,535 ports — don't miss services running on unusual ports

02

Quick Port Scan

```
nmap -sS --top-ports 1000 -T4 <target>
```

Fast stealth SYN scan on the 1000 most common ports — fast triage

05

Vulnerability Scripts

```
nmap --script=vuln <target>
```

Run NSE vulnerability scripts against the target to identify known CVEs

06

Save Results

```
nmap -oA full_scan <target>
```

Always save output in all formats for reporting and future reference

📋 COMMON PORTS CHEAT SHEET

PORT	SERVICE	PROTO	NOTES / ATTACK SURFACE
21	FTP	TCP	File Transfer — check for anonymous login
22	SSH	TCP	Secure Shell — brute force or key abuse
23	Telnet	TCP	Unencrypted shell — intercept credentials
25	SMTP	TCP	Email sending — enumerate users
53	DNS	TCP/UDP	Domain resolution — zone transfer attacks
80	HTTP	TCP	Web server — web application testing
110	POP3	TCP	Email retrieval
139	NetBIOS	TCP	Windows file sharing
143	IMAP	TCP	Email access protocol
161	SNMP	UDP	Network management — community strings
443	HTTPS	TCP	Encrypted web — check SSL/TLS config
445	SMB	TCP	Windows shares — EternalBlue target
3306	MySQL	TCP	Database — check for remote access
3389	RDP	TCP	Windows Remote Desktop — brute force
8080	HTTP Alt	TCP	Alternative web / proxy port

FURTHER NMAP

Key Takeaways

3 Core Scans

-sT full connect, -sS stealth SYN (default), -sU UDP — know when to use each

Special Scans

NULL, FIN, Xmas bypass basic IDS — but unreliable on Windows (RST for all)

NSE Scripts

Lua-powered scripts for vuln detection, brute force, service enum — massive power

Firewall Evasion

-Pn skips ICMP ping, -f fragments packets, --data-length adds noise

Key Switches

-sV versions, -O OS, -A aggressive, -oA save all, -T4 speed for CTFs

Always Enumerate

The more you know before attacking, the more options you have. Nmap first, always.